

Table of Contents

Cisco Secure Workload — APRA CPS 234

Reference Design | Australian APRA-Regulated Entities

Version: 1.0

Framework: APRA Prudential Standard CPS 234 — Information Security (effective 1 July 2019)

Use Case: Information asset segmentation, control implementation evidence, control testing inputs, incident management, third-party service-provider visibility

Framework version note. This reference design references CPS 234 as published in 2019. CPS 234 paragraph numbers are stable; APRA also operates additional related standards (e.g. CPS 230 — Operational Risk Management) which are not addressed here. Validate against APRA's published version before use in a supervisory or assurance engagement.

CSW UI navigation note. Cisco has not yet published CPS 234-specific CSW UI navigation; framework-specific paths are on the product roadmap. This reference design describes CSW *capabilities* and the *evidence artifacts* they produce.

Reader's Guide

Who this is for. Australian banks, insurers, superannuation trustees, and other APRA-regulated entities; their CISO function, technology risk and information security teams, internal audit, and the business owners who must attest to information asset control effectiveness under CPS 234.

Questions this reference design helps you answer:

- *Are information assets classified, and can I evidence which workloads support material business operations?* (Para. 20)
- *Are information security controls implemented in a manner commensurate with the assessed information security vulnerabilities and threats?* (Para. 21–23)
- *Can I produce control-testing evidence (Para. 29–33) from continuous workload telemetry rather than point-in-time samples?*
- *If a material information security incident occurs, can I rebuild the workload-level timeline needed for Para. 24–28 incident management and Para. 36–37 APRA notification scoping?*
- *Can I identify communication paths to third-party service providers that handle material information assets?* (Para. 21–23 in conjunction with related-party arrangements)

What you'll need. Information asset register, business operations criticality classification, supplier / related-party register, CMDB or cloud inventory, vulnerability management process, incident response reference design, internal audit plan, and application owner contacts.

Where to start. Sections 1–4 if you are scoping; 5–7 if you are designing and simulating policy; 9–10 if you are preparing for internal audit, external assurance, or APRA tripartite review within the quarter.

CSW primer — if you are new to Cisco Secure Workload

Cisco Secure Workload (CSW) is a **workload protection platform**. A lightweight **agent** on each server/VM/container observes processes and network flows; **cloud connectors** add AWS/Azure/GCP inventory where agents are not deployed.

CSW term	Meaning	Why compliance teams care
Scope	Logical boundary (CDE, PHI zone, CUI enclave)	Defines the systems you must prove are isolated
Label / filter	Tag or query assigning workloads to scopes	Automates scope membership — reduces drift
ADM	Application Dependency Mapping from observed traffic	Live network/data-flow diagram for assessors
Workspace	Policy container for one scope or application	Where allow/deny rules are authored
Monitor → Simulation → Enforce	Safe rollout sequence	Simulation = change-board evidence before blocking traffic
Denied Connections	Log of flows blocked by policy	Primary proof that enforcement operates

Console areas: Investigate (inventory, flows, vulns) · Defend/Segmentation (policy) · Manage (agents) · Platform (connectors) · Administration (audit log)

Read next: [Compliance evidence playbook](#) (full step-by-step) · [About CSW](#) (platform intro)

Universal evidence workflow

Execute these phases for **this framework's** compliance boundary. Map exports to control IDs in the **Reporting & Evidence** section below.

Phase	Goal	Key CSW actions	Typical duration
1 — Coverage	Every in-scope workload in CSW	Install agents/connectors ; apply compliance labels; create scope	Days 1–10
2 — Baseline	Machine-generated flow map	Run ADM ≥ 2 weeks; export clusters; app-owner signoff	Days 11–28
3 — Policy	Designed isolation before enforce	Build workspace; Simulation mode; fix false positives	Days 29–45
4 — Operate	Continuous proof between audits	Enforce; quarterly export pack; ADM refresh every 90 days	Ongoing

Phase 1 checklist (coverage)

- ☐ In-scope host list reconciled to CSW Inventory (100% or documented exceptions)
- ☐ Labels applied: `compliance:<framework>`, `data:<classification>`, `env:<tier>`
- ☐ CSW scope created matching compliance boundary
- ☐ **Export:** inventory CSV + agent status screenshot

Phase 2 checklist (baseline)

- ☐ ADM running on compliance scope for full business cycle (≥ 2 weeks)
- ☐ Unexpected flows documented (shadow IT, vendor egress, scope creep)
- ☐ App owners signed cluster-to-application mapping
- ☐ **Export:** ADM diagram + flow samples with process context

Phase 3 checklist (policy)

- ☐ Default-deny posture defined for sensitive scope
- ☐ ADM-imported rules refined; Simulation run ≥ 1 week
- ☐ Change tickets for false-positive fixes; exception register updated
- ☐ **Export:** policy export + simulation report

Phase 4 checklist (operate)

- ☐ Enforcement enabled on pilot scope; negative test recorded in Denied Connections
- ☐ Quarterly pack: inventory, policy, denies, vulns, audit log (see playbook)
- ☐ SIEM integration verified (sample events)
- ☐ **Export:** enforcement screenshot + quarterly binder

What CSW evidence does not replace

Physical access, HR/training records, encryption key management, signed BAAs/vendor contracts, formal pen tests, and assessor attestation still require separate programmes. CSW addresses the **workload-resident** slice: segmentation, flows, process context, vuln reachability, and change drift.

CSW effectiveness for this framework

- Critical information asset visibility
- Control testing evidence from simulation/enforce cadence
- Service-provider dependency flows

Compared to manual programmes: static diagrams and annual firewall samples age immediately; CSW ties evidence to **live workload behaviour** and produces queryable exports on demand — supporting "operating effectively" language in PCI v4.0, SOC 2 CC7, and HIPAA risk analysis.

1. Overview

CPS 234 is an outcome-based prudential standard. Its core obligations are: classify information assets by criticality and sensitivity (Para. 20), implement controls commensurate with the assessed threat (Para. 21–23), notify APRA of material information security control weaknesses and incidents (Para. 36–37), and systematically test the effectiveness of controls (Para. 29–33).

CSW can support **technical evidence** for the technology-control-effectiveness, information-asset-classification, network-segmentation, vulnerability-context, and incident-scoping dimensions of CPS 234. CSW does **not** replace board accountability for information security (Para. 13–14), the policy framework (Para. 16–19), the related-party assurance process, IAM/PAM, cryptography, BCP/DR, or APRA notification decisions.

CPS 234 Paragraph Map and CSW Relevance

CPS 234 paragraph	Topic	CSW relevance
13–15	Information security capability	Out of scope for CSW evidence directly; CSW outputs feed capability reporting
16–19	Policy framework	Out of scope (governance artefact)
20	Information asset identification and classification	Workload inventory; scope and label evidence; reachability mapping

CPS 234 paragraph	Topic	CSW relevance
21–23	Implementation of controls	Workload-level segmentation; ADM-derived allowlists; policy workspace
24–28	Incident management	Flow + process telemetry; forensic timeline; impact-scoping evidence
29–33	Testing of control effectiveness	Continuous flow + policy data; drift detection; policy-violation samples
34–35	Internal audit	Periodic evidence packs (Section 10)
36–37	APRA notification	Incident scoping inputs only; the notification decision is governance

Topics **out of scope** for CSW evidence: board oversight, policy framework, related-party contractual arrangements, IAM lifecycle, cryptography assurance, BCP/DR test outcomes, and APRA reporting decisions.

2. Pre-Deployment Checklist

- ☐ CSW cluster (SaaS or on-prem) provisioned
- ☐ Network reachability from in-scope workloads to the CSW cluster confirmed
- ☐ Linux / Windows agent compatibility verified across representative critical workloads
- ☐ Cloud accounts (AWS / Azure / GCP) connected for any in-scope cloud workloads
- ☐ Information asset register reviewed; "material" asset classification confirmed
- ☐ Stakeholders identified: CISO, Information Security Manager, Information Asset Owners, Internal Audit lead
- ☐ Change management window approved
- ☐ Evidence retention agreed with internal audit and the assurance partner

3. Phase 1 — Sensor & Connector Deployment (Days 1–5)

Deploy CSW telemetry sources in monitoring mode only.

- Install software sensors on representative workloads supporting material information assets
- Connect cloud accounts as read-only CSW cloud connectors where in-scope workloads run in cloud

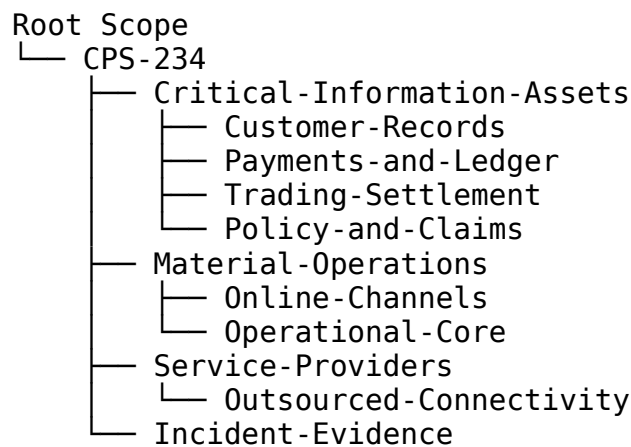
- Apply Day-1 labels: application, env, data_class, asset_criticality, owner, compliance=cps234
- Document any workloads that cannot be instrumented (managed SaaS, certain appliances) in a cannot-instrument register; this register is evidence in its own right

Sensor validation evidence: sensor inventory with status, version, last-checkin timestamp — retained as the Phase 1 baseline for control-testing comparisons later.

4. Phase 2 — Scope, Inventory, and Information Asset Classification (Days 6–10)

CPS 234 Para. 20 obliges entities to classify information assets by criticality and sensitivity. The CSW scope architecture should mirror that classification, not duplicate it.

4.1 Suggested Scope Architecture



4.2 Inventory Filters

Filter: Customer-Records-Candidates

- Tag (from asset register): data_class = customer
- Listening process: mysqld, postgres, oracle, sqlserver, mongod
- Listening port: 1521, 3306, 5432, 1433, 27017

Filter: Service-Provider-Edges

- Destination outside on-prem and cloud allow-lists
- Tag: managed_by = vendor

Filter: Operational-Core-Candidates

- Tag: asset_criticality = critical

4.3 Labeling Strategy

Label key	Example values	Why it matters for CPS 234
asset_criticality	critical, material,	Maps to Para. 20

Label key	Example values	Why it matters for CPS 234
	supporting	classification
data_class	customer, internal, public	Sensitivity dimension of Para. 20
application		Connects workload to information asset
env	production, uat, dev	Required for environment segregation evidence
owner		Accountability under Para. 14
compliance	cps234	Filters CSW evidence to the CPS 234 scope

5. Phase 3 — Application Dependency Mapping (Days 11–21)

5.1 ADM Configuration

For each scope in 4.1, create an ADM workspace; run across a representative business window that covers month-end and any quarterly reporting cycles. Minimum 2 weeks.

5.2 ADM Analysis for CPS 234

For each cluster, document:

Question	CPS 234 paragraph
Which workloads receive connections from outside the Critical-Information-Assets scope?	21–23
Are database connections encrypted?	21–23 (controls commensurate with threat)
Which workloads reach Service-Providers?	21–23 (third-party paths)
Are there unexpected lateral connections within Material-Operations?	24–28 (early indicator for incidents)
Which workloads are reached by administrative paths?	21–23 (privileged access surface)

5.3 Classification and Re-Scoping

1. Export ADM clusters and review with information asset owners.
2. Confirm classification (`asset_criticality`, `data_class`) for each cluster.

3. Apply or correct labels.
 4. Move workloads into the correct scope.
 5. Re-run ADM to produce the candidate policy.
-

6. Phase 4 — Policy Development (Days 22–35)

6.1 CPS-234-Aligned Policy Framework

Absolute policies:

DENY Any (default deny inbound)	→ Critical-Information-Assets
DENY Critical-Information-Assets (no direct internet egress)	→ Internet
DENY Corporate-IT (admin only via approved jump paths)	→ Critical-Information-Assets

Allowlist policies (examples to adapt per application):

ALLOW Channel-Layer tcp/443	→ Payments-and-Ledger
ALLOW Payments-and-Ledger tcp/<db-port-tls>	→ Customer-Records-DB
ALLOW Material-Operations tcp/636, tcp/88	→ Identity-Adjacent
ALLOW Jump-Hosts tcp/22, tcp/3389	→ Critical-Information-Assets
ALLOW Critical-Information-Assets tcp/443	→ Monitoring-Stack

Catch-all (audit everything else):

LOG Any (unmatched flows trigger alert)	→ Critical-Information-Assets
LOG Critical-Information-Assets (unmatched outbound)	→ Any

6.2 Policy Workspace Lifecycle

Phase	Mode	Duration	Purpose
1	Simulation	2 weeks	Validate against live traffic; tune false positives
2	Enforcement (high-confidence rules)	1 week	Internet egress deny; obvious deny rules
3	Full Enforcement	Ongoing	Workload allowlist enforced;

Phase	Mode	Duration	Purpose
			monthly exception review

Treat the policy workspace itself as control-implementation evidence (Para. 21–23) and snapshot it at each transition.

7. Phase 5 — Paragraph Mapping with CSW Evidence

CPS 234 paragraph	What CSW produces	How to use it
Para. 20	Workload inventory; scope + label export; reachability mapping	Evidence of asset identification and classification
Para. 21–23	Policy workspace; ADM-derived allowlist; vulnerability + reachability data	Evidence that controls are implemented and commensurate with threat
Para. 24–28	Flow + process search across the incident window	Incident impact scoping and timeline
Para. 29–33	Continuous flow data; policy-violation log; policy drift report	Control-effectiveness testing evidence (continuous, not point- in-time)
Para. 34–35	Periodic evidence pack (Section 10.1)	Internal audit work- paper input
Para. 36–37	Affected-workload list with timestamps and paths	Input to APRA notification scoping (decision is governance)

8. Phase 6 — Vulnerability & Risk Management

CSW vulnerability data is reachability-weighted. Use it to prioritise patching of internet-exposed and critical-information-asset-reachable workloads.

Compensating controls in CSW (when patch is delayed): restrict the vulnerable port to approved sources, add an anomaly alert on the affected process, log all connections, and record the exception in the workspace exception register (this register is itself evidence for Para. 21–23 risk acceptance).

9. Phase 7 — Monitoring & Alerting

Alert	Trigger	CPS 234 paragraph
Unauthorised reach to Critical-Information-Assets	Any unapproved source → CIA scope	21–23
Plaintext protocol detected on customer-record path	HTTP / FTP / unencrypted DB protocol from CIA	21–23
Lateral movement inside CIA	New east-west flow outside the approved baseline	24–28
External egress from CIA	CIA → external endpoint not on the allow-list	21–23 (third-party paths)
Policy violation	Enforced policy block triggered	21–23
Sensor offline	Agent stops reporting	29–33 (evidence integrity)

9.2 Forensic Telemetry

For an information security incident, the CSW forensic pack should contain:

- Flow log scoped to the affected workload(s) and time window (with process context)
- Process search output
- Policy workspace state at the time of the incident
- Vulnerability snapshot for the affected workload(s)

Retain incident packs per the entity's evidence retention policy and APRA expectations.

10. Reporting & Evidence Collection

10.1 Evidence per Audit / Assurance Cycle (quarterly recommended)

Evidence item	CSW source area	CPS 234 paragraph
Workload inventory snapshot	Inventory export	Para. 20
Scope + label membership	Scope membership export	Para. 20
Approved vs. observed flow comparison	ADM workspace export	Para. 21–23
Policy workspace snapshot	Policy workspace export	Para. 21–23

Evidence item	CSW source area	CPS 234 paragraph
Policy enforcement log / violations	Policy analysis output	Para. 21–23 and 29–33
Vulnerability exposure with reachability	Vulnerability report scoped to CPS-234	Para. 21–23
Service-provider egress summary	Flow search filtered to vendor endpoints	Para. 21–23 (third-party paths)
Incident timeline sample	Flow + process search for a representative incident	Para. 24–28
Exception register	Policy workspace exceptions list	Para. 21–23 (risk acceptance)

10.2 Ongoing Compliance Posture

- **Monthly:** scope / inventory hygiene review; service-provider egress reconciliation
- **Quarterly:** policy workspace review; refresh evidence pack 10.1
- **Annually:** independent walk-through with internal audit; refresh assumptions and baselines
- **Continuously:** policy drift detection and ADM re-run every 90 days

11. Common Pitfalls

Pitfall	Mitigation
Confusing CSW evidence with the entity's information security capability	CSW outputs are technical inputs; capability assessment is governance
Critical information assets missing labels	Reconcile information asset register ↔ CSW inventory monthly
Scope set by subnet rather than workload	Use process + label identity for scope membership
ADM run too short, missing month-end	Minimum 2-week observation; align to business cycles
Service-provider paths assumed safe because endpoint is internal	Service-provider scope membership and egress must be evidenced, not assumed
Plaintext protocols allow-listed by port	Identify protocols by process and observed handshake
Treating Para. 36–37 notification as automated from CSW	Notification is a governance decision; CSW provides scoping evidence only

Related Frameworks in This Repository

- [ISO/IEC 27001:2022](#)
 - [SOC 2 Type II](#)
 - [PCI DSS v4.0](#) — where the entity processes card data
 - [NIST SP 800-53 Rev 5](#) — useful technical control reference for control-design conversations
-

Document prepared for Cisco financial-services engagements in Australia. Replace [Customer Name] and any bracketed fields before customer delivery. Validate paragraph references against the current APRA publication.